

[INC-20261009-003] Suspicious Web3 Phishing Kit & Telegram Exfiltration Activity - GrabThePhisher Investigation

Executive Summary (Incident Write-up):

During triage of a suspected Web3 phishing site, we analyzed the kit's backend files (PHP/JS) targeting MetaMask wallet seed phrases. The script (metamask.php) captures user inputs, queries the Sypex Geo API (api.sypexgeo.net) to log victim IP and location data, and appends the stolen phrases locally to log.txt (3 compromised victims confirmed). Data is then exfiltrated via outbound HTTPS requests directly to an attacker-controlled Telegram Bot (api.telegram.org/bot5457463144:AAG8t4k7e2ew3tTi0IBShcWbSia0Irvxm10/sendMessage). The bot token (5457463144:AAG8t4k7e2ew3tTi0IBShcWbSia0Irvxm10) and chat ID (5442785564) were extracted, and takedown procedures have been initiated.

Artifacts:

- **Target Wallet:** MetaMask
- **Affected Infrastructure:** Web3 Phishing Server / Web Application
- **Compromised Data Type:** 12/24-word Secret Recovery Phrase (Seed Phrase), Victim IP, Geolocation Telemetry
- **Scope/Impact:** 3 confirmed compromised victims recorded in server logs
- **Adversary Telegram Bot Token:** 5457463144:AAG8t4k7e2ew3tTi0IBShcWbSia0Irvxm10
- **Adversary Telegram Chat ID:** 5442785564
- **Exfiltration Endpoint:**
<https://api.telegram.org/bot5457463144:AAG8t4k7e2ew3tTi0IBShcWbSia0Irvxm10/sendMessage>
- **Target Chat Parameter:** chat_id=5442785564
- **External Profiling Service:** <http://api.sypexgeo.net/json/>
- **Critical Script Files:** metamask/metamask.php, metamask/index.html, metamask/log.txt
- **Date/Time that the event was noticed:** 10/09/2026 19:00 UTC
- **Alert time stamp:** 10/09/2026 19:00 UTC
- **Number of systems identified:** 1 Web Server (Phishing Host) / 3 Compromised External Victim Accounts

Text explaining why below data is important to IOCs:

The source code forensics confirm active credential theft targeting Web3 decentralized finance (DeFi) assets. Harvesting seed phrases grants the adversary complete, irreversible control over the victims' crypto assets, smart contract allowances, and wallet permissions. The observed Telegram Bot API calls highlight modern Living-off-the-Cloud (LotC) exfiltration tactics designed to blend in with legitimate outbound web traffic and evade perimeter egress filtering. The adversary identifiers (Bot Token 5457463144:AAG8t4k7e2ew3tTi0IBShcWbSia0Irvxm10 and Chat ID 5442785564) provide actionable attribution for C2 disruption, while the local log.txt file serves as concrete forensic proof of scope, confirming successful exploitation and data staging prior to network-level interception.

Declaration:

True Pos. - Issue, because of that was a dynamic incident.

Recommendations:

- **Takedown & Domain Blacklisting:** Enforce perimeter firewall, proxy, and DNS sinkhole blocks for all domains, subdomains, and hosting IP addresses hosting the GrabThePhisher kit.
- **Telegram Bot Neutralization:** Submit abuse and takedown requests directly to Telegram Support with the exposed bot token (5457463144:AAG8t4k7e2ew3tTi0IBShcWbSia0Irvxm10) and chat ID (5442785564) to revoke API credentials and disable the C2 channel.
- **Perimeter Egress Filtering:** Block or monitor anomalous outbound HTTP/HTTPS requests originating from internal web servers toward messaging API endpoints (e.g., api.telegram.org).
- **Victim Identity & Asset Containment:** For the 3 identified compromised victims, immediately flag associated public addresses, revoke connected Web3 permissions, and initiate asset migration to newly created and secured wallets.
- **Threat Hunting:** Scan web server roots and proxy logs for similar POST URI patterns, API tokens, and references to api.sypexgeo.net or unauthorized Telegram bot calls.

References:

- <https://cyberdefenders.org/blueteam-ctf-challenges/grabthephisher/>